PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Panorama de la cybermenace 2024

03-120 ANSSI - Panorama de la cybermenace 2024 — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Les vulnérabilités des équipements de bordure constituent plus de la moitié des opérations de cyberdéfense les plus critiques de l'ANSSI.
2. L'espionnage chinois évolue vers un ciblage opportuniste pour obtenir des contrats a posteriori, comme l'illustre le cas de l'entreprise I-SOON.
3. La porosité entre acteurs étatiques et cybercriminels via le partage d'outils et d'infrastructures complique l'attribution des attaques.

Tendances de la menace 2024

Notion	À retenir
Hausse événements	En 2024, **4386** événements traités (**+15 %** par rapport à 2023), dont **3004** signalements et **1361** incidents. Hausse liée aux **Jeux olympiques** (pic en **juillet**).
Panorama structuré	Le document distingue : **1.** les opportunités, **2.** les moyens mis en œuvre et **3.** la finalité des attaques.

Opportunités pour les attaquants

Notion	À retenir
JOP Paris 2024	Jusqu'à **10 fois** plus d'attaques qu'à Tokyo. Deux attaques majeures par rançongiciel : **BrainCipher** (Grand Palais-RMN, début août) et **WhiteRabbit** (Université Paris-Saclay, 11 août 2024). Aucune attaque n'a perturbé les Jeux.
Triptyque SSI	Sécurisation (réduit exposition/latéralisation), supervision (analyse des journaux) et réponse à incident. Priorité : annuaire **Active Directory**. Windows 10 (fin de support **14 octobre 2025**) : **82 %** des postes.
Équipements de bordure	Exploitation massive de vulnérabilités (pare-feux, passerelles VPN). **Plus de la moitié** des opérations de cyberdéfense de l'ANSSI. Les **9 vulnérabilités les plus exploitées** visaient toutes la bordure (**Ivanti**, **Palo Alto Networks**, **Fortinet**…).

Indicateurs de vulnérabilités et obsolescence

82 %
postes de travail des organismes utilisateurs du service ADS utilisant Windows 10
fin de support le **14 octobre 2025**

36 %
serveurs Windows dans une version obsolète

40
dossiers de coordination de vulnérabilités traités par le CERT-FR en 2024
contre **7** en 2020

236
signalements de vulnérabilités reçus par le CERT-FR en 2024

Moyens mis en œuvre par les attaquants

Notion	À retenir
Chaîne d'approvisionnement	Piéger un logiciel pour atteindre ses utilisateurs (**NotPetya** 2017, **SolarWinds** 2020, **XZ Utils** sur **3 ans**).
Anonymisation et États	Réseaux de machines compromises (**APT28**, **Nobelium** lié au **SVR** russe) ou industrialisés (**Volt Typhoon** chinois, techniques **Living off the Land**).
Mercenariat et prestataires	Écosystème privé chinois (**I-SOON**, fuite **février 2024**) ciblant **45 pays** ; processus de **Pall Mall** lancé par **France** et **Royaume-Uni** en **février 2024**.

Finalités des attaques

Notion	À retenir
Attaques à but lucratif	En 2024, **144** compromissions par rançongiciel. **PME, TPE et ETI** les plus affectées ; enseignement supérieur **12 %**. **39** souches : **LockBit 3.0** (**15 %**), **Ransomhub** (**7 %**) et **Akira** (**7 %**) dominent.
Déstabilisation et espionnage	Hausse de la **déstabilisation** (hacktivistes, **DDoS**). L'**espionnage** cible les **télécommunications** et **intérêts stratégiques étatiques**. **Territoires ultramarins** particulièrement exposés.

Pièges et confusions

- ⚠ Confondre un signalement (comportement anormal) avec un incident (action malveillante réussie sur le SI).
- ⚠ Croire que l'espionnage chinois repose uniquement sur des contrats étatiques ciblés.
- ⚠ Penser que les acteurs étatiques et les cybercriminels sont des silos strictement séparés.
- ⚠ Oublier que le durcissement vise à ralentir la progression d'un attaquant et non seulement à l'empêcher d'entrer.

Sigles et définitions

Signalement — comportement anormal ou inattendu pouvant avoir un caractère malveillant

Incident — événement de sécurité où l'ANSSI confirme qu'un acteur malveillant a conduit des actions avec succès sur le SI

Living off the Land (LoTL) — technique consistant à utiliser les outils déjà présents sur le système d'information ciblé

Ransomware as a Service (RaaS) — modèle économique où un opérateur fournit des ressources de rançongiciel à des affiliés contre un pourcentage

Supply-chain — compromission d'un éditeur, projet open source ou prestataire pour atteindre ses clients par rebond

ADINT — technique exploitant les failles du marché publicitaire pour associer un équipement à son utilisateur

LIOP — secteur des entreprises privées développant des capacités d'attaque informatique pour des États ou clients privés

Auto-test

1. Quelle est la différence entre un signalement et un incident ?
2. Quelle souche de rançongiciel était la plus représentée en 2024 ?
3. Quel est le rôle d'un courtier en accès initiaux ?
4. Combien de compromissions par rançongiciel l'ANSSI a-t-elle connues en 2024 ?
5. Quelle technique utilise les outils déjà présents sur le système ciblé ?

Réponses : **1.** Le signalement est un comportement anormal, l'incident est une action malveillante réussie. · **2.** LockBit 3.0 (15 %). · **3.** Obtenir et revendre des accès non autorisés à un SI. · **4.** 144, un niveau comparable à 2023. · **5.** La technique Living off the Land (LoTL).

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.